SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no	192465008	**Name of the Student**	S.TANISHA

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I ___S.TANISHA (192465008)___ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student S.TANISHA

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)
Key points: malware types (virus, worm, trojan, ransomware, spyware); phishing via deceptive emails, links or sites to steal credentials; DoS from a single source versus DDoS from a botnet; preventive measures such as antivirus, user awareness training, rate limiting, firewalls and CDN or traffic scrubbing.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)
Key points: the attacker intercepts and may alter communication between two parties; techniques include ARP poisoning, rogue Wi-Fi access points, DNS spoofing and session hijacking; countermeasures include HTTPS/TLS, VPN, certificate validation, HSTS and dynamic ARP inspection.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)
Key points: spoofing is forging identity (IP, MAC, email or DNS spoofing); sniffing is passively capturing packets (Wireshark, tcpdump) and mainly exposes unencrypted data; prevention includes encryption, switched networks, port security and anti-spoofing filters.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)
Key points: the process is asset identification, scanning (Nessus, OpenVAS), analysis, risk rating and reporting; the report contains an executive summary, scope and methodology, findings with CVE IDs, CVSS severity scores, evidence, risk impact and prioritized remediation recommendations; also mention how it differs from penetration testing.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)
Key points: OSINT draws on public sources such as WHOIS, Shodan, social media, news, forums, code repositories and the CVE/NVD databases; also cover commercial and internal sources (logs, honeypots) and collection techniques such as passive collection, web scraping and DNS or domain lookups; mention legal and ethical considerations.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)
Key points: IoCs are artifacts such as file hashes, malicious IPs, domains, URLs, registry keys and unusual network traffic; threat feeds (open-source or commercial, in formats like STIX/TAXII) deliver them for SIEM or firewall blocking and faster detection; limitations include false positives, stale data and the need for context.

ANSWER

Q1. Explain the common types of network attacks: Malware, Phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 Marks)

1. Malware

Malware is malicious software designed to damage systems, steal information or gain unauthorized access.

Types of malware:

- **Virus:** Attaches itself to files and spreads when they are executed.
- **Worm:** Spreads automatically across networks.
- **Trojan:** Disguises itself as legitimate software.
- **Ransomware:** Encrypts files and demands money to restore them.
- **Spyware:** Secretly monitors users and collects information.

Example: WannaCry ransomware encrypted files and demanded ransom.

Prevention: Install updated antivirus software and avoid downloading files from untrusted sources.

2. Phishing

Phishing is an attack in which attackers use fake emails, messages or websites to steal sensitive information, such as passwords and banking details.

Example: A fake bank email asks a user to click a link and enter their banking credentials.

Prevention: Avoid suspicious links, verify the sender and provide security awareness training to users.

3. Denial of Service (DoS)

A DoS attack floods a server or network with excessive requests from a single source, making the service unavailable to legitimate users.

Example: An attacker sends excessive requests to a college website, causing it to become unavailable.

Prevention: Use firewalls and rate limiting to control excessive traffic.

4. Distributed Denial of Service (DDoS)

A DDoS attack floods a target with traffic from multiple compromised devices, often called a botnet.

Example: Attackers use thousands of infected computers to overwhelm an online shopping website.

Prevention: Use a Content Delivery Network (CDN), DDoS protection services and traffic filtering.

Difference: DoS generally uses a single source, whereas DDoS uses multiple sources.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works, the techniques used and the countermeasures. (8 Marks)

Definition

A Man-in-the-Middle (MitM) attack occurs when an attacker secretly intercepts communication between two parties and may read or modify the exchanged information.

How it works

1. A user connects to a website or another device.
2. The attacker positions themselves between the communicating parties.
3. The attacker intercepts the communication.
4. The attacker may steal sensitive information or modify messages.
5. The user and the other party may remain unaware of the attack.

Example: An attacker intercepts a user's login information through an insecure public Wi-Fi network.

Techniques used

1. **ARP Poisoning:** Sends false ARP messages to redirect local network traffic through the attacker.
2. **Rogue Wi-Fi Access Point:** Creates a fake Wi-Fi network to intercept users' traffic.
3. **DNS Spoofing:** Provides false DNS information to redirect users to fraudulent websites.
4. **Session Hijacking:** Takes control of an authenticated user's session by stealing or abusing session credentials.

Countermeasures

- **HTTPS/TLS:** Encrypts communication between users and websites.
- **VPN:** Protects network traffic through an encrypted tunnel.
- **Certificate Validation:** Helps verify the website's identity.
- **HSTS:** Forces supported browsers to use HTTPS for a website.
- **Dynamic ARP Inspection:** Helps prevent ARP spoofing on supported managed networks.
- **Avoid Untrusted Wi-Fi:** Do not access sensitive accounts through suspicious public networks.

Conclusion: Encryption, proper certificate validation and secure network configurations help prevent MitM attacks.

Q3. Differentiate between Spoofing and Sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 Marks)

Definition

Spoofing: An attack in which an attacker falsifies an identity or address to appear as a trusted source.

Sniffing: The process of capturing and examining network packets to observe data travelling across a network.

Difference between Spoofing and Sniffing

Spoofing	Sniffing
Involves faking an identity or address.	Involves capturing network packets.
Can be used to deceive systems or users.	Can be used to monitor network communication.
Often involves sending forged information.	Can be passive, without modifying traffic.
Example: IP spoofing.	Example: Capturing unencrypted login traffic.
Prevention includes authentication and anti-spoofing filters.	Prevention includes encryption and network monitoring.

Types of spoofing

1. **IP Spoofing:** The attacker forges the source IP address in network packets.
2. **MAC Spoofing:** The attacker changes a device's MAC address to impersonate another device.
3. **Email Spoofing:** The attacker forges the sender information in an email.
4. **DNS Spoofing:** The attacker provides false DNS information to redirect users to fraudulent websites.

How to detect or prevent sniffing

- **Encryption:** Use HTTPS/TLS to protect data from being read in transit.
- **Secure Wi-Fi:** Use WPA2 or WPA3 security.
- **Network Monitoring:** Use tools such as Wireshark to examine suspicious network traffic.
- **Port Security:** Restrict which devices can connect to switch ports.
- **Secure Network Configuration:** Use switched networks and disable unnecessary network services.
- **Avoid Plaintext Protocols:** Replace insecure protocols with encrypted alternatives.

Conclusion: Spoofing deceives systems by falsifying identity, while sniffing captures network traffic. Authentication, encryption and network monitoring help reduce both risks.

Q4. Define Vulnerability Assessment. Explain its steps and describe the contents of a good Vulnerability Assessment Report. (8 Marks)

Definition

A Vulnerability Assessment is a systematic process of identifying, analysing and prioritising security weaknesses in computer systems, networks and applications.

Steps in Vulnerability Assessment

Step 1: Asset Identification
Identify the systems, servers, applications and network devices to be assessed.

Step 2: Define Scope
Determine which systems are included and obtain proper authorisation.

Step 3: Vulnerability Scanning
Use tools such as Nessus or OpenVAS to identify known vulnerabilities and security weaknesses.

Step 4: Analyse Findings
Examine the scan results and verify whether the reported vulnerabilities are relevant.

Step 5: Risk Assessment
Assign severity levels such as Critical, High, Medium and Low based on risk.

Step 6: Reporting
Document the vulnerabilities, evidence, impacts and recommended solutions.

Step 7: Remediation and Reassessment
Fix the identified weaknesses and perform another assessment to check whether they have been resolved.

Contents of a Vulnerability Assessment Report

1. **Executive Summary:** Brief overview of the assessment and major findings.
2. **Scope and Methodology:** Systems assessed and methods or tools used.
3. **Identified Vulnerabilities:** List of detected security weaknesses.
4. **CVE ID:** Common Vulnerabilities and Exposures identifier, where applicable.
5. **Risk Level:** Severity of each vulnerability, such as High or Medium.
6. **Evidence:** Scan results, affected systems and relevant observations.
7. **Impact:** Possible consequences if the vulnerability is exploited.
8. **Recommendations:** Suggested steps to fix or reduce the risk.
9. **Conclusion:** Overall security status and recommended next steps.

Difference between Vulnerability Assessment and Penetration Testing

Vulnerability Assessment	Penetration Testing
Identifies and prioritises security weaknesses.	Tests whether selected weaknesses can be exploited.
Usually focuses on broad vulnerability coverage.	Focuses on validating exploitability and attack paths.
Commonly uses automated scanning and analysis.	Uses controlled manual and automated testing.

Conclusion: Vulnerability assessment helps organisations identify weaknesses early and take corrective action before attackers exploit them.

Q5. What is Open-Source Intelligence (OSINT)? Discuss common threat data sources and the techniques used to collect threat data. (8 Marks)

Definition

Open-Source Intelligence (OSINT) is the process of collecting and analysing information from publicly available sources to obtain useful intelligence.

In cybersecurity, OSINT helps identify potential threats, exposed systems, malicious activities and security risks.

Common Threat Data Sources

1. Public Websites and Search Engines

- Used to find publicly available information about organisations, technologies and security incidents.
- Examples: Google and Bing.

2. WHOIS and DNS Records

- WHOIS provides domain registration information when available.
- DNS records provide information about domain names and their associated services.

3. Shodan

- Helps discover internet-connected devices and services that may be publicly exposed.

4. Social Media

- Platforms such as LinkedIn and X may reveal information about employees, technologies or security incidents.

5. News Websites and Security Blogs

- Provide information about recent cyberattacks, data breaches and emerging threats.

6. Code Repositories

- Platforms such as GitHub may contain information about software vulnerabilities or accidentally exposed secrets.

7. CVE and NVD Databases

- CVE provides identifiers for publicly disclosed vulnerabilities.

- NVD provides vulnerability information, including severity scores and references.

8. Commercial and Internal Sources

- Commercial threat intelligence feeds provide curated information about malicious IP addresses, domains and other threats.
- Internal sources include firewall logs, SIEM alerts and honeypot observations.

Techniques Used to Collect Threat Data

1. **Passive Collection:** Gathering information from public websites, DNS records and online databases without directly testing the target's systems.
2. **Web Scraping:** Automatically extracting permitted information from websites.
3. **DNS Lookup:** Examining DNS records to understand domain configurations.
4. **WHOIS Lookup:** Checking available domain registration details.
5. **Search Engine Dorking:** Using advanced search operators to locate publicly indexed information.
6. **Threat Feed Integration:** Collecting threat indicators from open-source or commercial feeds.
7. **Log Analysis:** Analysing internal security logs to identify suspicious activities.

Legal and Ethical Considerations

- Use only authorised and lawful collection methods.
- Respect privacy and applicable data protection laws.
- Follow website terms of service and access restrictions.
- Do not attempt unauthorised access to systems.

Conclusion: OSINT helps security teams gather threat information from different sources and use it to improve threat detection and risk assessment.

Q6. What are Indicators of Compromise (IoCs)? Explain their types and describe how threat feeds help organisations improve their defence. (8 Marks)

Definition

Indicators of Compromise (IoCs) are pieces of evidence that may indicate a computer system or network has been compromised or involved in malicious activity.

They help security teams identify and investigate potential cyberattacks.

Types of IoCs

1.FileHashes
Unique values used to identify files and compare them against known malicious files.

Example: A SHA-256 hash matching a known malware sample.

2.MaliciousIPAddresses
IP addresses associated with suspicious or known malicious activity.

Example: A server communicating with an IP address associated with a known command-and-control infrastructure.

3.MaliciousDomains
Domain names linked to phishing, malware distribution or command-and-control activity.

Example: A fake domain created to imitate a banking website.

4.SuspiciousURLs
Web addresses associated with phishing or malware downloads.

Example: A fraudulent login page designed to steal passwords.

5.RegistryKeys
Unexpected registry entries that may indicate malware persistence on Windows systems.

6.EmailIndicators
Suspicious sender addresses, email headers or attachments associated with phishing campaigns.

7.NetworkBehaviour
Unusual network traffic, repeated connections to suspicious destinations or unexpected data transfers.

How Threat Feeds Improve Security

Threat intelligence feeds provide regularly updated information about known threats and IoCs.

1.EarlyThreatDetection
Help security teams identify known malicious IP addresses, domains and files.

2.AutomatedBlocking
Firewalls and security gateways can block relevant malicious indicators.

3.SIEMIntegration
Security Information and Event Management (SIEM) systems can compare logs with IoCs and generate alerts.

4.FasterIncidentResponse
Help security analysts investigate suspicious activity and identify potentially affected systems.

5.ThreatIntelligenceSharing
Organisations can exchange threat information using standard formats such as STIX and TAXII.

6ImprovedSecurityMonitoring
Updated indicators help organisations recognise known attack infrastructure and campaigns.

Limitations of IoCs and Threat Feeds

- **False Positives:** Legitimate activity may be incorrectly flagged as malicious.
- **Outdated Information:** Attackers may change IP addresses, domains and file hashes.
- **Lack of Context:** An indicator alone may not prove that a system is compromised.
- **Need for Validation:** Security teams should verify indicators and assess their relevance before taking action.

Conclusion: IoCs and threat intelligence feeds help organisations detect known threats, block suspicious activity and respond to security incidents more quickly. They are most effective when combined with contextual analysis and other security controls.